

INFORMATION SECURITY REGULATION

This regulation supports the Information Security Protection (ISP) which provides specific instructions to classify, maintain, protect, and support Loudoun County Public School (LCPS) assets, including but not limited to, security controls for passwords, authorized system access, timely reporting of compromised data or lost devices, and ensuring all compliance guidelines are met. The Information Security Regulation (ISR) clarifies operating practices regarding data collection, dissemination, and use, while enhancing communication and transparency with parents, students, and staff.

A. Responsibilities

1. The Chief Technology Officer for Digital Innovation is responsible for ensuring the guidance, direction, and responsibility of information security activities for the School Division and will name a Department of Digital Innovation (DDI) designee (the Supervisor of Information Security) to carry out the following responsibilities:

- a. Adopting, maintaining, implementing, administering, and interpreting organization-wide information security policies, regulations, standards, guidelines, and procedures.
- b. Performing information systems risk assessments, preparing information systems security action plans, evaluating information security products, and performing other activities necessary to assure a secure information systems environment.
- c. Collaborate and support all division Departments as requested or needed regarding information security activities.
- d. If alleged computer or network security compromises violate School Board policies or laws, the Department of Digital Innovation will collaborate with the appropriate parties in conducting due process and fact finding, and any relevant information will be shared with the relevant parties or agencies for appropriate action.

2. Owner: All owners are those individuals/departments for which the information was created and who are authorized to make and communicate judgments, decisions, and ensuring employee awareness regarding the importance, availability, and sensitivity of the information.

- a. Owners must comply with any law, statute, policy, regulation, pertinent to information assets.
- b. Owners must authorize access and assign custody as appropriate.

3. Custodian: All custodians are those individuals responsible for the technical control over an information asset. The custodian has administrator, system

INFORMATION SECURITY REGULATION

administrator, or root account access. The custodian will execute access in accordance with the guidelines developed by the owner.

4. Users: All users are those individuals in departments of the School Division, affiliates, subsidiaries, staff, students, contractors, consultants, temporaries, including those users affiliated with third parties who access, process, and use School Division information assets that may be located in division facilities or other off-site locations. All users will comply with the requirements specified by information security policy and any supporting regulations.

B. System Access and Privileges

1. Access to School Division systems and applications will be granted only when authorized, appropriate, and compliant with LCPS policy and relevant legal requirements. To help establish accountability, any records reflecting this access must be retained until the user's employment, enrollment and/or contract has ended.

2. Individuals who fall outside of the definition of users must not be granted a user-ID or otherwise be given privileges to use School Division computers or communications systems unless advance written approval has first been obtained.

3. Whenever possible temporary privileges granted to users (vendors, contractors, etc.) should be granted for a limited period of time (180 days or less is recommended). As needed, temporary users should have their privileges reauthorized by the sponsoring department head.

4. Before privileges are granted all temporary users (vendors, contractors, etc.) must sign an acknowledgement stating they have read and understand the applicable Acceptable/Responsible Use Policy.

5. By accessing School Division systems, users voluntarily consent to all policies and regulations, and to having actions, emails, or other electronic activity monitored, recorded, seized, and disclosed by authorized School Division personnel. Exemptions to this may be listed in the applicable Acceptable/Responsible Use Policy (AUP/RUP) or other School Division policies.

6. All users shall have all access privileges revoked in a timely manner upon the termination of employment, enrollment, contract, and/or the "need to know." Owners and custodians shall reevaluate the access privileges granted to users annually. In response to feedback, the administrator or designee must promptly revoke all privileges no longer needed by users and/or where systems software permits, after ninety (90) days of inactivity (30 days in the case of newly assigned IDs).

INFORMATION SECURITY REGULATION

C. Information Classification

1. In order to effectively secure LCPS information, we must have a classification scheme that we can use to describe the information, the risk level associated with exposure or loss and the amount of protection required. This classification scheme is to be applied to all LCPS information (physical and electronic), the systems that process it (portable computers, desktop computers, servers, voice mail systems, etc.), the physical location of where information is housed (removable media, onsite, vendor site, cloud storage, etc.), or the methods by which it is moved or transmitted (public networks, electronic mail, face-to-face conversation, etc.).

2. Information classification is necessary to support the allocation of resources for the protection of information assets, as well as determining the potential loss, damage, and disclosure of confidential or private information. The Department of Digital Innovation (DDI) is responsible for evaluating and maintaining the information classification scheme and revising it as needed. In order to effectively secure LCPS information, DDI will regularly reevaluate the classification of School Division information to ensure the assigned classification is still appropriate based on changes to legal and contractual obligations as well as changes in the use of the information or its value to the School Division. The classification scheme below consists of three hierarchical categories into which all LCPS information can be divided:

a. Confidential Information (High Risk)

- (i) Confidential - Information shall be classified as High Risk when the unauthorized disclosure, alteration or destruction of that information could cause a high level of risk to the School Division or its affiliates or violate federal laws or state laws related to information privacy. High Risk information is highly sensitive and may be restricted by federal or state law. The highest level of security controls shall be applied to protect this level of information.
- (ii) Access to High Risk information shall be controlled from creation to destruction, and shall be granted only to those persons affiliated with the School Division who require such access in order to perform their job and have a legitimate educational interest or a valid business need. Access to High Risk information shall be individually requested and then authorized by the Information Owner who is responsible for the information.

INFORMATION SECURITY REGULATION

b. Internal/Private Information (Medium Risk)

- (i) Internal/Private – Information shall be classified as Medium Risk when the unauthorized disclosure, alteration or destruction of that information could result in a medium level of risk to the School Division or its affiliates. To ensure the security and integrity of all information, the default information classification for any information asset is Internal/Private Information.
- (ii) By default, all information assets that are not explicitly classified as High Risk or Public information (see b 3.C below) will be treated as Medium Risk information. Reasonable levels of security controls shall be applied to internal information.
- (iii) Access to Medium Risk information shall be requested from, and authorized by, the Information Owner who is responsible for the asset. Access may be authorized to groups of persons by their job classification or responsibilities (“role-based” access).

c. Public Information (Low Risk)

- (i) Public Information- Public information is defined as a Low Risk asset that any entity, either internal or external, to LCPS can freely access. The disclosure use or destruction of Low Risk information will have limited effects on the School Division nor carry any significant liability.
- (ii) While minimal controls are required to protect Public information, some level of control is required to prevent unauthorized modification, release, or destruction of assets.

D. Information Access

1. User access to information for viewing, modification or other purposes must be restricted based on the category of information and the roles assigned to the user based on a valid business or educational need.

2. All users of LCPS systems must be assigned one or more “roles.” Examples of such roles are including but not limited to: Student, Teacher, Administrator, Database Administrator, Developer, Human Resources and Talent Development, Business and Finance, Support Staff, Senior/Executive Management, and Information

INFORMATION SECURITY REGULATION

Security. Within applications, roles are further defined to limit access on a “need to know” basis.

3. Users shall take appropriate security precautions to encrypt or otherwise protect High or Medium Risk assets when accessing it in locations outside of the School Division network.

E. Information Administration

1. Labeling: As a best practice, High Risk assets should be electronically or physically identified as “Confidential” when feasible. Use caution when sending email and ensure the intended recipient understands the information or asset may be sensitive in nature.

2. Separation of Production Data Environments from Other Environments: Development, test, or training data shall be kept either physically or logically separate from production information. Copies of production assets shall not be used for testing unless the information no longer contains sensitive information or unless all personnel involved in testing have authorized access to the information.

3. Disclosure: High Risk information must only be disclosed after the information owner's explicit authorization has been obtained. If an individual has been granted access to High Risk information, this does not imply the authority to disclose it to other persons. As applicable, compliance with existing record disclosure practices for students and employees should be upheld.

4. Encryption: When appropriate, High Risk information must be encrypted with the aid of approved encryption programs when stored on electronic media. Likewise, whenever High Risk information is transmitted over any public network, it must be sent in encrypted form.

5. Printing/Copies

- a. Printing or copying High Risk assets should not take place without the advance permission of the owner. School Division multi-functional devices (MFDs) should use access control measures such as secure print or key code access at all times when available.
- b. Printers should not be left unattended if High Risk assets are being printed or will soon be printed. Access control measures or secure print capability should be used to prevent unauthorized persons from viewing the material being printed. The persons attending the device should be authorized to examine the asset being printed.

INFORMATION SECURITY REGULATION

6. Distribution/Transport

- a. High Risk assets in hardcopy form should be shipped or sent through internal or external mails in a sealed envelope marked "Open by Addressee Only" or equivalent.
- b. High and Medium Risk assets in hardcopy form should be sent by trusted courier or registered mail to ensure the asset is tracked.
- c. Alternatively, this type of asset may be made available to only the designated recipients via methods noted above and including digital lockers or other physical security methods.
- d. High Risk assets must not be left out in the open in an unoccupied or unsecured office.
- e. High Risk assets must not be faxed unless at least one of the following conditions prevails at both the originating and receiving sites: (1) an authorized user is on hand to properly handle the materials, or (2) a password protected fax or MFD is used to restrict unauthorized release of the materials. When High Risk information is faxed, a cover sheet should be used with a disclaimer statement regarding the level classification of the asset.
- f. High Risk assets must not be communicated or transmitted using hand-held portable two-way receivers as well as cellular "smart" phones unless the connection is encrypted, or the asset being transmitted is protected from unauthorized access.

7. Storage and Recovery

- a. When not in use, High Risk assets must always be protected from unauthorized disclosure. When left in an unattended room, such assets should be locked away in secure containers.
- b. All High Risk assets resident on computer systems must be periodically backed-up and depending on the importance of the assets for the continuity of the operation, stored off-site in a physically secured or cloud-hosted location.
- c. The medium used for storing High Risk assets must be of high quality and periodically tested to ensure that it can properly record, process, backup and restore the assets in question. Media that can no longer reliably retain assets must not be used for archival storage.

INFORMATION SECURITY REGULATION

8. Destruction/Disposal

- a. The Library of Virginia (LVA) specifies the records retention schedules for School Division data. As practical, all assets regardless of classification should have markings that indicate a date, or event, after which the asset should be destroyed to avoid unnecessary protection of asset. Unless the type of asset is specifically listed on the LVA General Schedule for records retention, assets shall be retained for as long as necessary but for no longer. Assets listed on the LVA Records Retention Schedule should be retained for the period specified and destroyed according to the permissible methods.
- b. Before storage media is sent to a vendor for trade-in or disposal, all High Risk and/or Medium Risk information must be destroyed or concealed according to methods approved by DDI and/or the LVA General Schedule for records retention and destruction.
- c. When the time comes to destroy High Risk or Medium Risk assets captured on storage media (such as hard drives or removable storage and media such as USB memory sticks, CDs and DVD's), approved degaussers, or forensic "data wiping" programs must be used. It is not sufficient simply to "erase" files from computer storage media. Alternatively, shredders, or other methods approved by DDI may be employed.
- d. All waste copies of High Risk or Medium Risk assets that are generated in the course of copying, printing, or otherwise handling should be destroyed according LVA methods which include shredding, incinerating, or pulping.

9. Third Party Offsite Storage and Transportation: Anytime a third party is used for the transportation and/or storage of High Risk assets, the vendor must demonstrate controls greater than or equal to the applicable School Division policy. Additional details are provided in the Data Protection Addendum (DPA) required of all purchase orders and contracts for all software, cloud-based applications, email services, document storage or other related internet-based or web-based tools including PaaS, SaaS, and IaaS services.

F. Lost or Stolen Device. When it has been determined that an LCPS-owned device has been lost or stolen, the following procedure is required:

1. The owner or custodian of the device must report this loss immediately to his or her supervisor.

INFORMATION SECURITY REGULATION

2. The employee and supervisor must immediately initiate an assessment to determine what type of data is contained on or accessible by the lost or stolen device.

3. The supervisor must report the device loss and results of the assessment and actions taken to the DDI designee.

4. The DDI designee shall report, as soon as possible, the device loss and results of the assessment and actions to date to the Chief Technology Officer for Digital Innovation.

G. Authentication and Passwords

1. Multi-Factor Authentication:

- a. Multi-Factor Authentication (MFA) solutions can significantly enhance the security of the login process by requiring that users not only memorize passwords, but also prove that they have possession of a physical item (such as an authentication token) or submit to biometric scanning (such as fingerprint recognition).
- b. When feasible, MFA should be enabled for access to all LCPS computing and network resources.
- c. Administrative or Privileged accounts, excluding service accounts, must use MFA. Administrative accounts - a username and password that grants an individual privileged access to the IT System. Privileged access is access to make changes to the overall IT System.
- d. There are 3 primary MFA verification methods:
 - (i) Something the user knows. Example: Username and password.
 - (ii) Something the user has. Example: Cell phone (authentication app, text message or voice call), a physical token.
 - (iii) Something the user "is" (biometric). Example: Fingerprint, voice, retinal scan, etc.

INFORMATION SECURITY REGULATION

2. Passwords:

- a. All passwords are to be treated as High Risk assets. Passwords shall be the responsibility of the individual for which it was assigned. Individuals are accountable for all actions taken with their password. Passwords should not be shared, including any students or staff.
- b. Wherever systems software permits, the display and printing of passwords should be masked, suppressed, or otherwise obscured such that unauthorized parties will not be able to observe or subsequently recover them.
- c. Wherever systems software permits, the initial passwords issued to a new user by an administrator should be valid only for the new user's first session. At that time, the user should be forced to choose another password. This same process applies to the resetting of passwords in the event that a user forgets a password.
- d. Passwords must never be stored in an unsecured manner. For example, passwords must not be stored and/or transmitted in clear (unencrypted) text. This includes unencrypted email messages or other forms of electronic communication. This also includes visible notations on paper.
- e. Use of an encrypted password storage application (password manager or password vault tool) is acceptable, although extreme care should be taken to protect access to said application.
- f. All user-level and network-level administrative passwords must conform to and/or exceed the requirements described below.

3. Password Construction Requirements

- a. All School Division employees, contractors, vendors, agents, and students (exclusive of grades PK-1 and special exceptions) are required to use strong passwords. Strong passwords have the following characteristics:
 - (i) Are between 8 and 128 characters long.
 - (ii) Do not contain the user's Account Name or entire Display Name.

INFORMATION SECURITY REGULATION

- (iii) Contain three of the following types of characters: (a) uppercase letters, (b) lowercase letters, (c) numbers (0 through 9), and/or (d) non-alphanumeric characters (special characters): (~!@#\$%^&* _-+=`|\\(){}[];:"'<>,.?/).
- (iv) Must be unique and not be re-used.

4. Changing Passwords:

- a. When MFA is enabled for a staff account, regular password changes are not a requirement, however, staff may change their password at any time.
- b. Privileged accounts and Service account passwords must be changed at least annually or upon a personnel change in the group managing the account or with access to the password.
- c. If an account or password is suspected to have been compromised, users must immediately report the incident and change all passwords.
- d. All default passwords should be changed before any computer or communications system is used for School Division business. This regulation applies to passwords associated with end-user accounts, as well as passwords associated with systems administrator and other privileged accounts.
- e. Whenever system access has been compromised, or even if there is a compelling reason to believe that it has been compromised, the responsible system administrator must immediately: (a) change all relevant passwords or force a password change in the impacted system upon the next login.
- f. Self-service password resets may be available to students and staff. Unless provided, student password resets are to be done in person by authorized school-based staff members. Staff password resets for the School Division network can only be accomplished by contacting the DDI Technology Support Center. As a minimum control, users shall supply their User ID, their personal identification number and must be calling via an LCPS phone number or a personal number on record. It is a policy violation for a non-School Division user or another user to call on behalf of a user with the intention of requesting a password reset.

INFORMATION SECURITY REGULATION

H. Network and Remote Access

1. Users are prohibited from attempting to circumvent or subvert the provisions of this regulation or the applicable AUP/RUP. This does not preclude the use of security tools by appropriately authorized personnel for the purpose of conducting network vulnerability assessments and investigations, or other authorized business need.

2. Devices connecting to the network should be configured and maintained in such a manner as to prohibit unauthorized access or misuse.

3. Levels of security access provided shall be appropriate to the need of the person seeking access, and no greater, and may be denied at any time if necessary, to preserve the availability and integrity of the network.

4. Organizations, vendors and/or individuals who wish to establish remote access solutions to School Division networks shall obtain prior approval from DDI.

5. It is the responsibility of users with remote access privileges such as Virtual Private Network (VPN) to ensure that their remote access connection is given the same consideration as the user's on-site connection to the School Division. The remote user has the responsibility to take all necessary steps to prevent unauthorized access of School Division internal networks and information assets.

6. Remote connections using "always connected" (broadband or any other "high speed") Internet connections shall also utilize an approved and properly configured firewall (hardware-based devices are preferred). All unnecessary ports shall be closed (especially inbound ports) and Network Address Translation (NAT) used.

7. Unauthorized access to School Division networking equipment (firewalls, routers, switches, etc.) is prohibited. This includes port scanning or connection attempts using applications such as SSH/SNMP, or otherwise attempting to interact with School Division network equipment.

8. Users of remote computers should ensure that School Division-owned or any personal equipment used to connect to the School Division network is not connected to any other remote network VPN at the same time. All VPN devices/applications shall be configured so that all Internet traffic passes through the VPN "tunnel". Reconfiguration of a remote user's equipment for the purpose of defeating this security measure, such as the practice of "split tunneling" is not permitted.

9. Third party vendors must NOT be given remote access privileges to School Division computers and/or networks unless the involved system owner determines that they have a bona fide need to be given such access. These privileges must be enabled

INFORMATION SECURITY REGULATION

only for the time period required to accomplish the approved tasks (such as remote maintenance) and require the approval by DDI Information Security or designate.

10. Accessing email and other LCPS resources from outside of the LCPS network may require the use of MFA. MFA is mandatory for all Virtual Private Network (VPN) and privileged remote access. Users who opt to not use MFA will not be able to access the network remotely and will be required to access the network from an LCPS facility.

I. Information Security Awareness Training

1. It is required that all new School Division users complete information security awareness training prior to, or at least within 30 days of, being granted access to any School Division system resource.

2. All School Division users are required to complete annual information security awareness training.

3. All users must annually sign an acknowledgement stating they have read and understand the applicable Acceptable/Responsible Use Policy.

4. All users shall be provided with sufficient training and/or supporting reference materials, such as the asset classification schema, to allow them to properly protect School Division assets.

J. Disaster Recovery Plan

1. DDI will create and maintain an Information Technology Disaster Recovery Plan (DRP) to ensure the availability of systems supporting critical processes in the event of natural or man-made disaster. The DRP should list the information technology systems and infrastructure supporting critical processes (as identified by the School Division). The DRP must then detail how these systems will be made available within division-designated Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO). Further, the DRP must designate roles and responsibilities for disaster scenarios and include the contact information of responsible parties.

2. The DRP must be tested periodically. The results of the test must be recorded and used to modify the plan and/or the District's recovery capabilities to ensure adherence to the District's RTO and RPO.

K. Incident Response Plan

1. DDI will create and maintain an Information Security Incident Response Plan (IRP) that identifies and describes goals, expectations, roles, and responsibilities

INFORMATION SECURITY REGULATION

with respect to information security incident preparation, detection, activation/response, containment, notification remediation, resolution, and after-action analysis.

2. The IRP must be tested periodically. The results of the test must be recorded and used to modify the plan and/or the District's incident response capabilities.

L. Reporting and Notifications

1. All users with access to LCPS resources and information are required to immediately report any suspected or actual security incidents to DDI Information Security.

2. Following the IRP, the District will provide information about data breaches as directed by the division's legal counsel and required by federal and state laws, and LCPS regulations and/or policies.

M. Enforcement. The Supervisor of Information Security shall conduct security reviews as needed to ensure that the ISP and ISR are enforced in accordance with best practices.

N. Exceptions. The Chief Technology Officer for Digital Innovation acknowledges that, under rare circumstances, certain users will need to employ systems that are not compliant with these regulations. All such instances shall be approved in writing and in advance by the Chief Technology Officer for Digital Innovation.

O. Contact Point. Questions about these regulations should be directed to the Chief Technology Officer for Digital Innovation and/or the appropriate departmental level designate.

P. Compliance. Failure to comply with this policy may result in disciplinary or legal action.

Issued: 10/25/16

Current Revision: 08/01/22

Legal Refs: Family Educational Rights and Privacy Act [34 CFR §99.3](#)

Cross Refs: Policy [7566](#), Employee Technology Acceptable/Responsible Use Policy, Policy [8650](#), Student Technology Acceptable/Responsible Use Policy